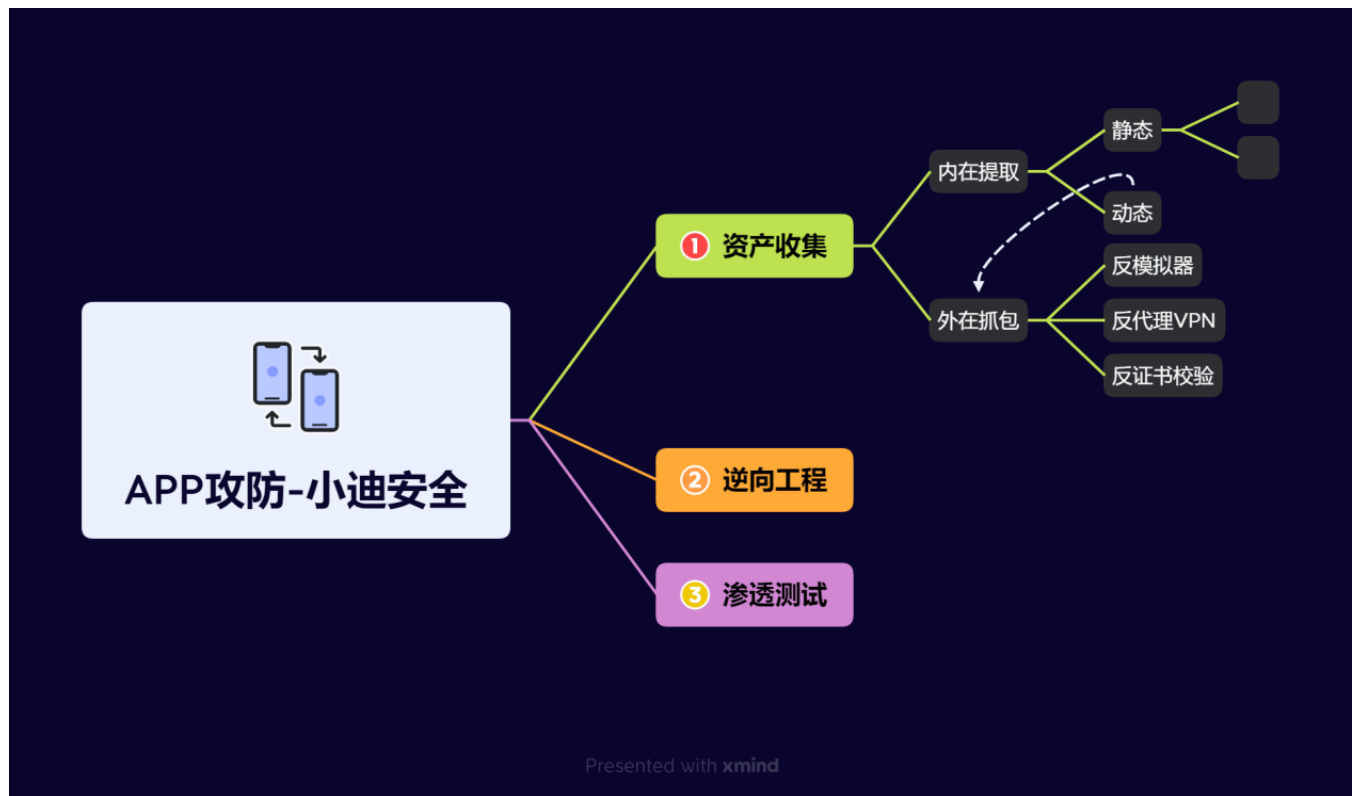


Day90 APP攻防-小程序篇&反编译&外在抓包&主包分包&配置泄漏&算法逆向&未授权



1.知识点

- 1、APP资产-抓包突破&反模拟器
- 2、APP资产-抓包突破&反证书检验
- 3、APP资产-抓包突破&反代理VPN

-
- 1、单向校验-XP框架&Frida&HOOK
 - 2、双向校验-Frida&HOOK&导入证书
 - 3、单项双向-逆向删除反代码重打包

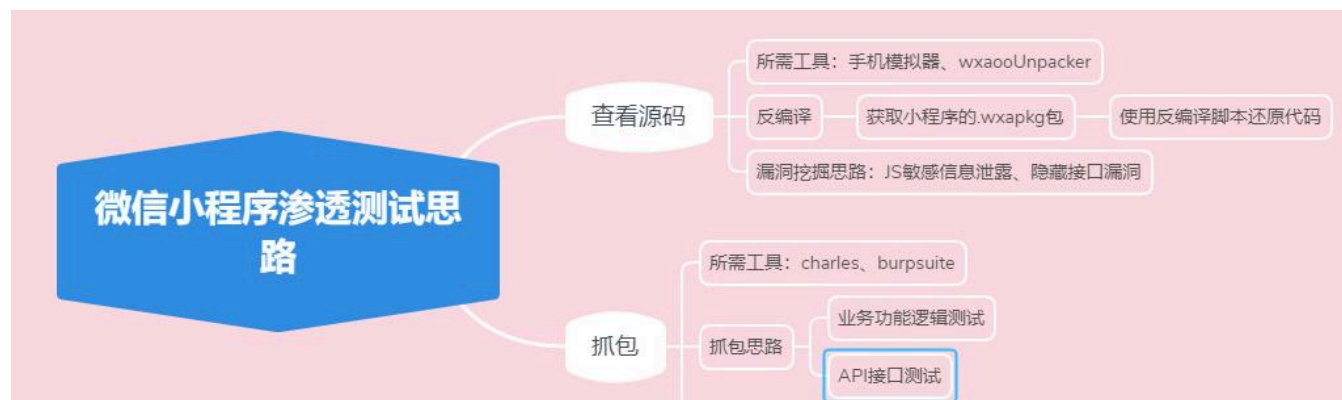
-
- 1、APK逆向-数据修改-结构&格式
 - 2、APK逆向-逻辑修改-Smail语法
 - 3、APK逆向-视图修改-Activity&Xml

-
- 1、APK逆向-反编译&动态调试-Jeb&Adb
 - 2、APK逆向-反编译&动态调试-算法分析
 - 3、APK逆向-反编译&动态调试-会员机制

- 1、APK逆向-反编译&LSP&HOOK-绕检测
- 2、APK逆向-反编译&LSP&HOOK-加密算法
- 3、APK逆向-反编译&LSP&HOOK-逻辑验证

- 1、小程序抓包-全局代理&进程转发
- 2、小程序逆向-反编译&主包&分包&调试
- 3、小程序安全挖掘-抓包&接口&配置泄漏

2.演示案例



2.1 小程序抓包-全局代理&进程转发

- 1 不管是在真机还是模拟器中在安卓系统上抓包，可能会存在以下问题：
- 2
- 3 安卓系统 7.0以下版本，不管微信任意版本，都会信任系统提供的证书
- 4 安卓系统 7.0 以上版本，微信 7.0 以下版本，微信会信任系统提供的证书
- 5 安卓系统 7.0 以上版本，微信 7.0 以上版本，微信只信任它自己配置的证书列表
- 6 相应的解决办法就是如下：
- 7
- 8 将证书安装到系统证书中（需root）
- 9 苹果手机（苹果手机不受此影响）
- 10 采用安卓系统低于7.0的模拟器
- 11
- 12 1、全局代理-BurpSuite&科来等
- 13 2、进程转发-Proxifier+BurpSuite

2.2 小程序逆向-反编译&主包&分包&调试



- 1 反编译项目:
- 2 1、wxpUnpacker
- 3 <https://github.com/sanriqing/WxAppUnpacker>
- 4 2、小锦哥小工具
- 5 <https://www.xjgxcx.xiejijin.com/>
- 6 3、分包-unveilr
- 7 <https://github.com/r3x5ur/unveilr>
- 8 4、小程序开发者工具
- 9 <https://q.qq.com/wiki/tools/devtool/>

2.3 小程序安全挖掘-抓包&接口&配置泄漏



- 1 见第90-1天：小程序抓包反编译安全挖掘案例